



Guardrails e **anti-prompt-injection** em automações com LLM

Autor: PDI Marcos Luciano - marcosluciano.rodrigues@v4company.com

Unidade: FV Marketing / V4 Company: Automação & Infraestrutura

Módulo: 06 | Governança de IA e Segurança

Data: Setembro 2026

Status: **NÃO PUBLICADO** · Desenvolvido / Homologação pendente

Versão: 1.0

pdi-governanca-ia-seguranca-a1

1. Contexto

Resumo de leads, triagem de tickets e geração de copy consomem texto livre de usuários, páginas, e-mails e planilhas. Cada fonte externa é um vetor: o modelo não distingue com segurança instrução de dado, então qualquer texto na janela vira candidato a comando.

Esta atividade padroniza a barreira em **5 camadas** para que cada novo fluxo com LLM nasça com teto de dano conhecido e auditável, alinhado ao OWASP Top 10 para LLMs.

2. Diagnóstico

Injeção direta ("ignore as instruções anteriores") e indireta (instrução oculta no documento que o bot resume) desviam o modelo, vazam contexto do system prompt ou disparam ação indevida via ferramenta conectada. Saída sem contrato vira execução sem dono (OWASP LLM01 e LLM02).

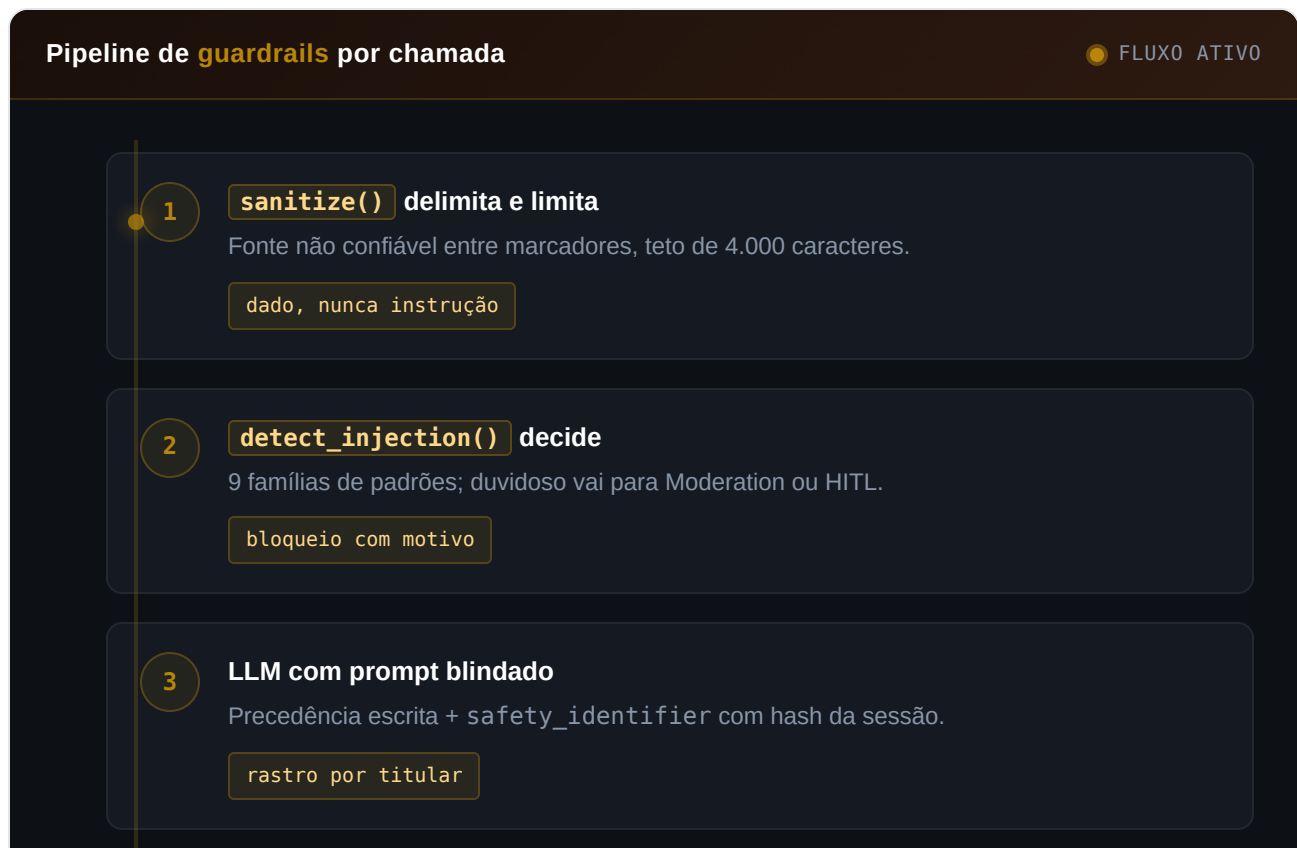
VETOR	EXEMPLO	BARREIRA
Direta	Usuário digita ordem de exfiltrar	<code>detect_injection</code> + Moderation
Indireta	Texto oculto no documento resumido	Delimitador + detector
Output inseguro	Chamada de ferramenta não validada	<code>validate_output</code> + HITL

3. Solução

Proxy de guardrails em Python puro com 3 funções (`sanitize`, `detect_injection` com 9 famílias de padrões, `validate_output` por contrato JSON), system prompt blindado com precedência escrita, `safety_identifier` com hash por sessão e HITL obrigatório em escrita em CRM, Ads, banco ou mensagem ao cliente.

- Standard com modelo de ameaça, 6 camadas e red team de 60 casos
- Código com self-test de 9 casos, todos passando
- Checklist de ativação por automação

4. Como funciona



4

`validate_output()` valida

Só passa JSON com as chaves do contrato, sem HTML ativo.

`fora do contrato, descarta`

5

HITL + auditoria

Ação sensível exige humano; tudo vai para a trilha.

`dano irreversível eliminado`

guardrail_proxy.py | Python puro, sem dependências

self-test: 9/9 passando

5. Entregas

ARQUIVO	CONTEÚDO
<code>1-standards/STANDARD-GUARDRAILS-LLM.md</code>	Ameaça, 6 camadas, red team, proibições
<code>2-implementacao/guardrail_proxy.py</code>	Proxy executável com self-test 9/9
<code>2-implementacao/CHECKLIST-GUARDRAILS.md</code>	Ativação por automação, 8 itens
<code>7-apresentacao/</code>	Deck de 12 slides, demo, roteiro com 5 Q and A, este relatório em HTML, DOCX e PDF

6. Métricas de sucesso

MÉTRICA	ATUAL	META
Bloqueio em bateria de 60 injeções	0% (sem proteção)	95% (meta)
Latência p95 adicionada	não medida	abaixo de 150 ms (meta)
Alto risco com HITL	0%	100% (meta)

Status: Desenvolvido em Setembro 2026, homologação pendente: ligar Moderation API no piloto de resumo de tickets e publicar o primeiro placar adversarial.